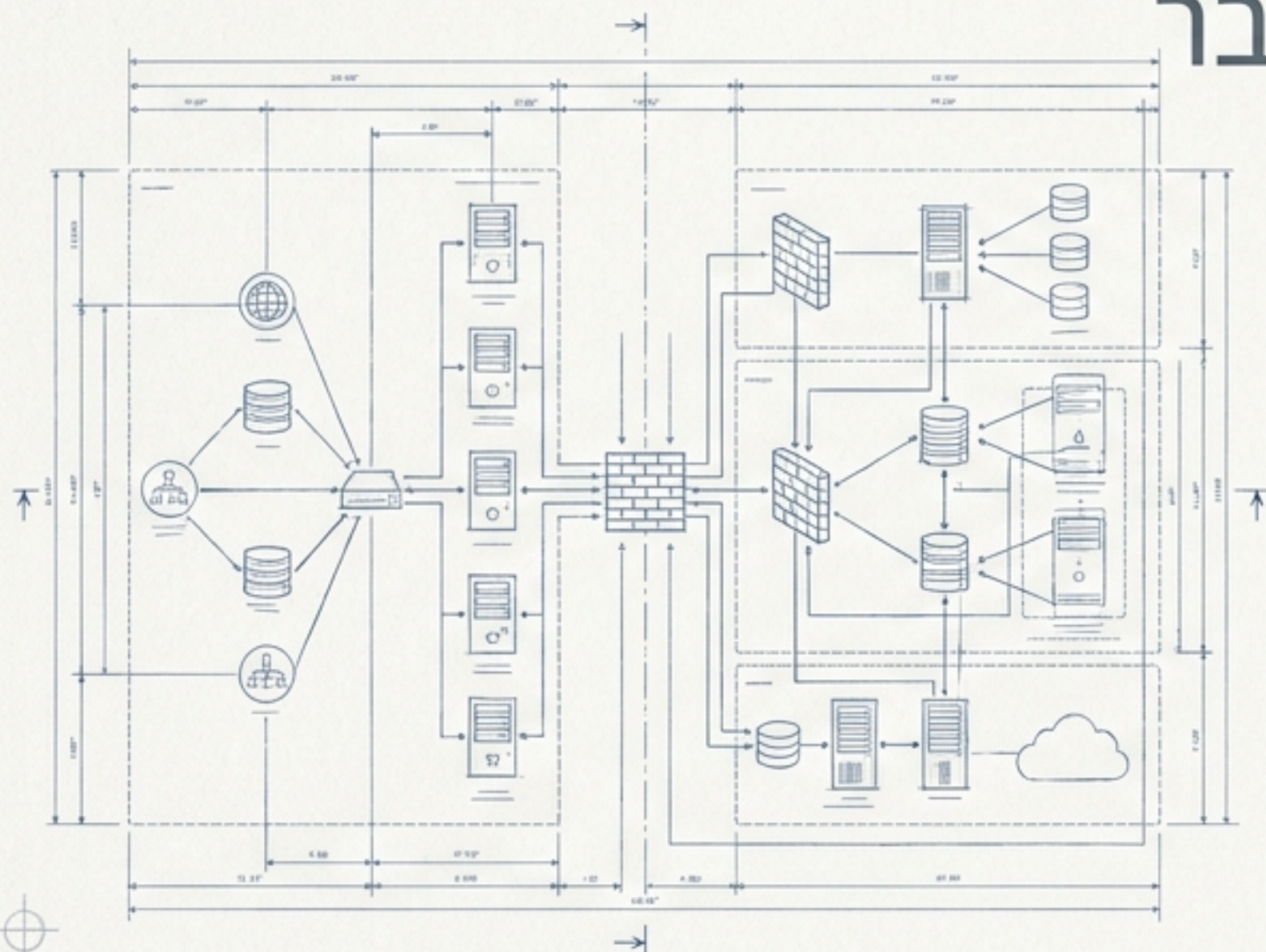


איום מתקדם ומתמשך (APT)

המדריך האסטרטגי לריגול סייבר
ולמערכות תקיפה ארוכות-טווח.



מסמך זה נועד למקבלי החלטות, מנהלי IT ומומחי אבטחה, ומספק ניתוח חזותי של אנטומיית התקיפה, שיטות הפעולה של קבוצות בחסות-מדינה, ואסטרטגיות ואסטרטגיות הגנה מודרניות.

סכנה שקטה: מציאות "זמן השייה" (Dwell Time)

זמן השייה החציון – משך הזמן שבו תוקפי APT פועלים ברשת מבלי להתגלות – ממחיש את עוצמת האיום. חלון זמן זה מאפשר להם להתפשט ולהשיג את יעדיהם באין מפריע.

אמריקה

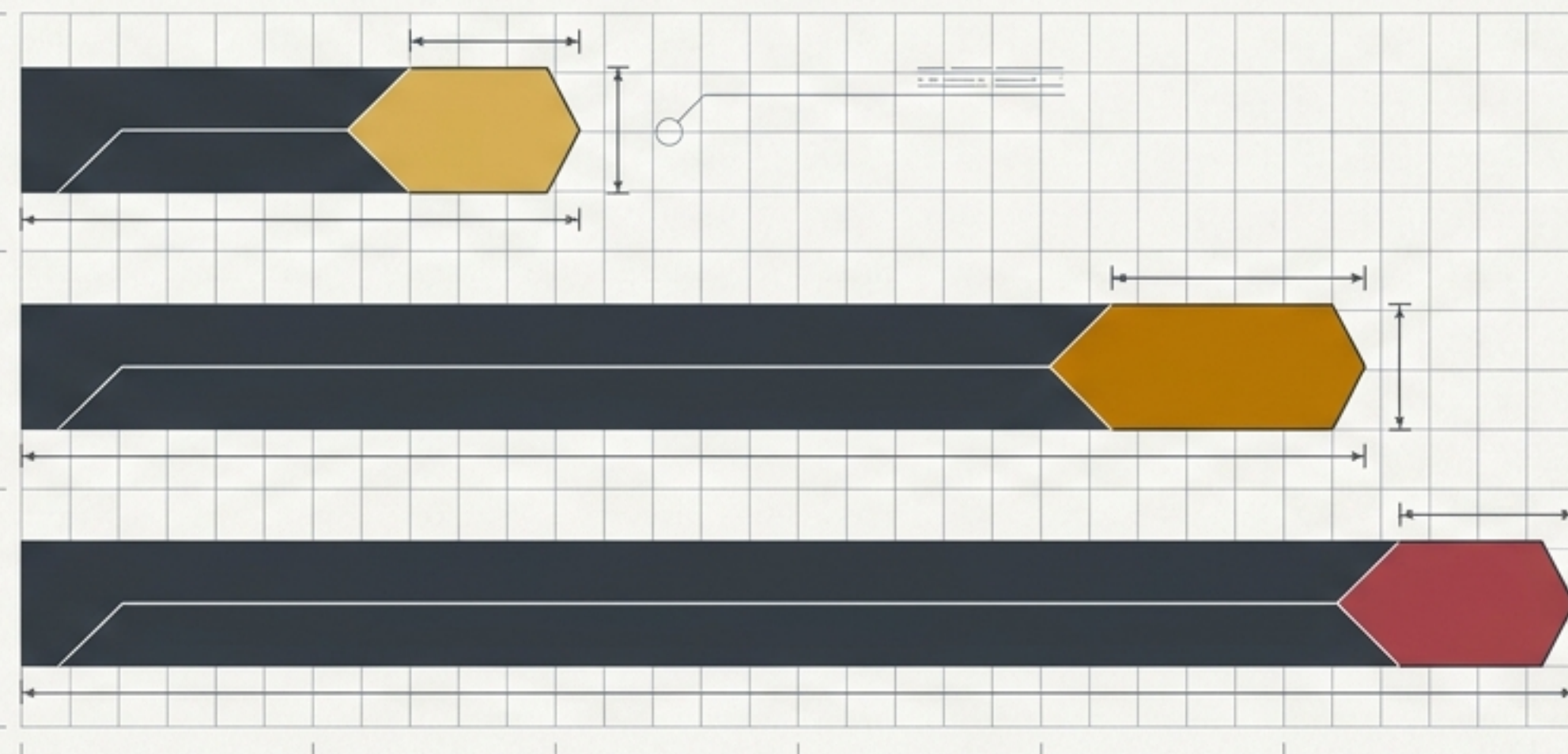
71 ימים

אירופה, המזרח התיכון
ואפריקה (EMEA)

177 ימים

אסיה והאוקיינוס
השקט (APAC)

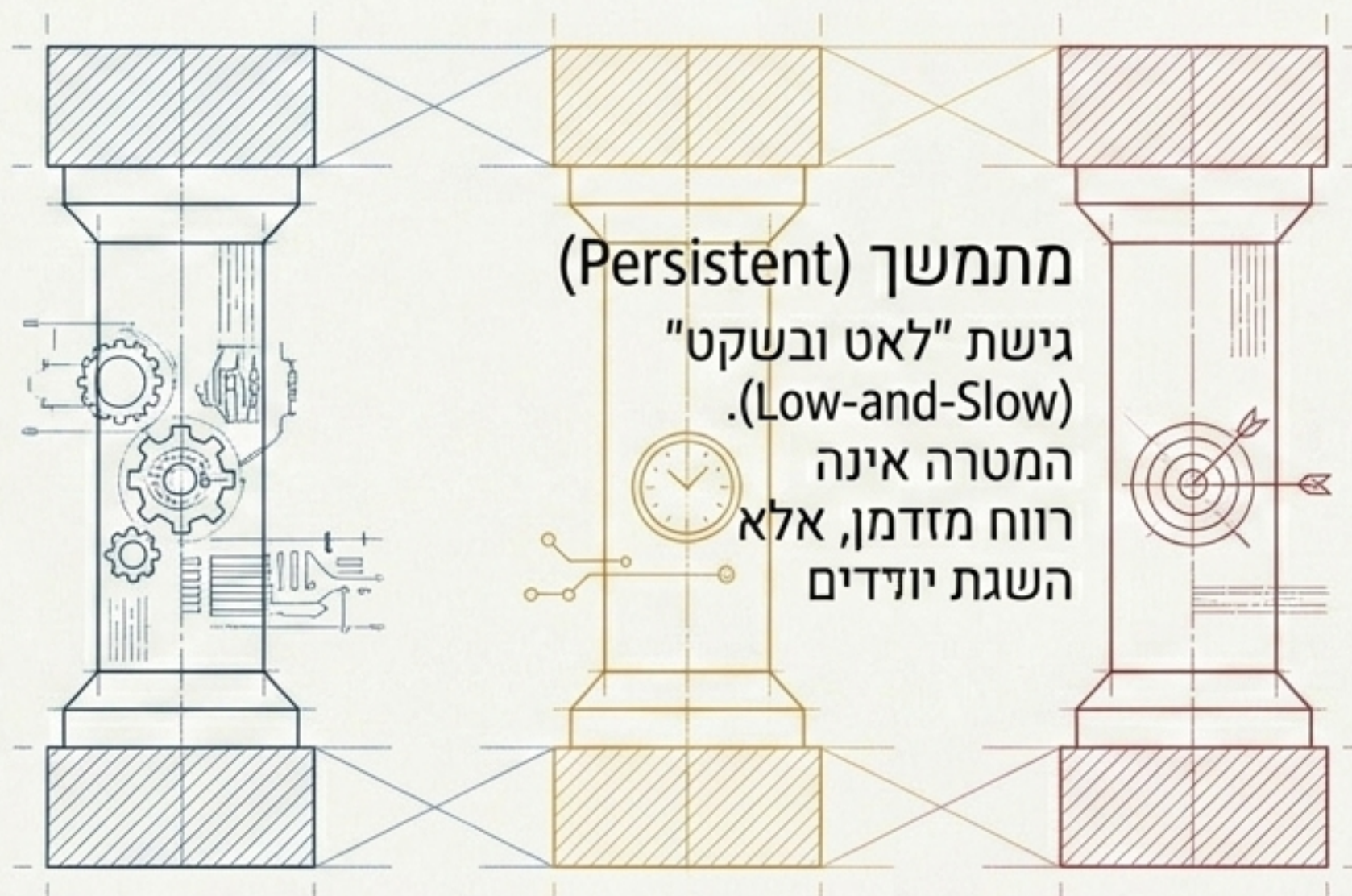
204 ימים



(מקור הנתונים: FireEye, 2018)

מודל ה-APT: לא עוד וירוס אוטומטי

איומים אלו מונעים לרוב על ידי ישויות מדיניות או קבוצות ממומנות היטב, הפועלות כיחידות מודיעין אנושיות ומתואמות.



מתקדם (Advanced)

שימוש בטכניקות איסוף מודיעין מקיפות, שילוב של כלים מסחריים, חולשות אבטחה ופיתוח מותאם אישית.

אבטחת מידע מבצעית (OPSEC) קפדנית המבדילה אותם מתוקפים "פשוטים".

מתמשך (Persistent)

גישת "לאט ובשקט" (Low-and-Slow).

המטרה אינה רווח מזדמן, אלא השגת יודדים

איום (Threat)

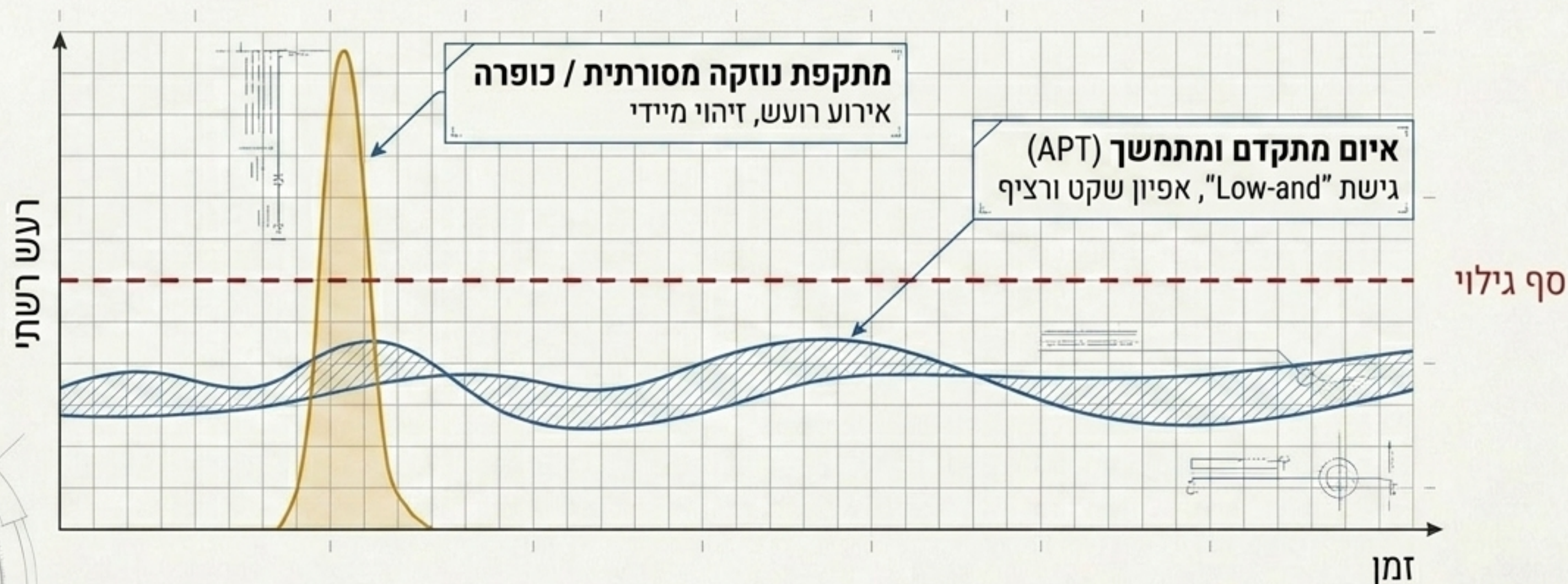
שילוב מסוכן של יכולת וכוונה.

מדובר בפעולות אנושיות מתואמות, ממומנות ומאורגנות, ולא בקטעי קוד אוטומטיים ועיוורים.

(Source: Intelligence Report, 2024)

פרדיגמת החמקנות: רעש מול התגנבות

טכנולוגיות אבטחה מסורתיות מחפשות חריגות עוצמתיות. תוקפי APT מעוצבים במכוון כדי להישאר מתחת לרדאר תוך השתלבות בתעבורה הלגיטימית של הרשת.

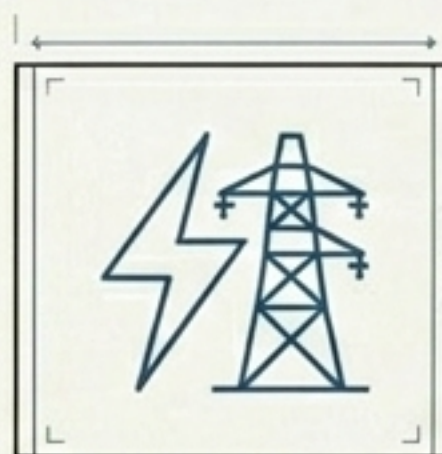


מטרות בעלות ערך גבוה: מטריצת התשתיות הקריטיות

כל מגזר עסקי מרכזי המחזיק בכמות גדולה של מידע רגיש, קניין רוחני או נתונים אישיים נמצא בסיכון יעד. אלו אינן פריצות מזדמנות, אלא מערכות ריגול תעשייתי ומדיני.



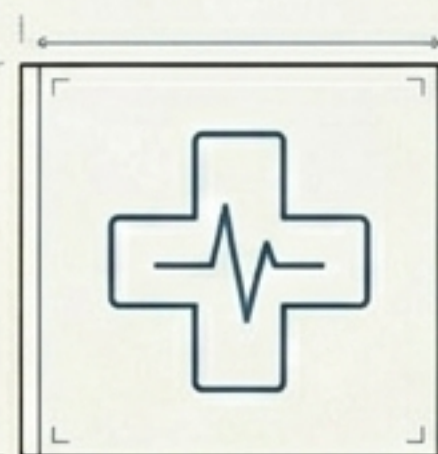
חקלאות



אנרגיה



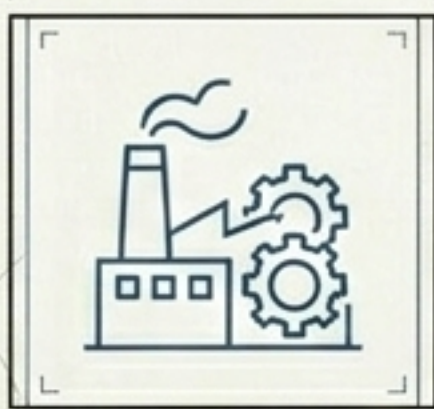
מוסדות פיננסיים



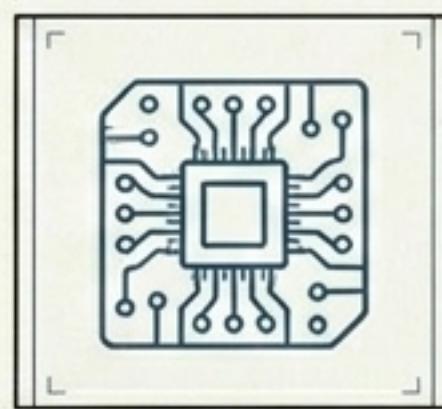
שירותי בריאות



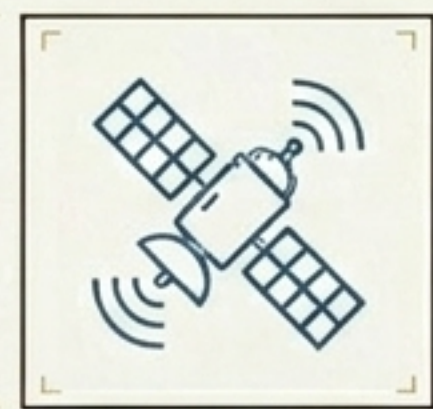
השכלה גבוהה



ייצור ותעשייה



טכנולוגיה



תקשורת



תקשורת

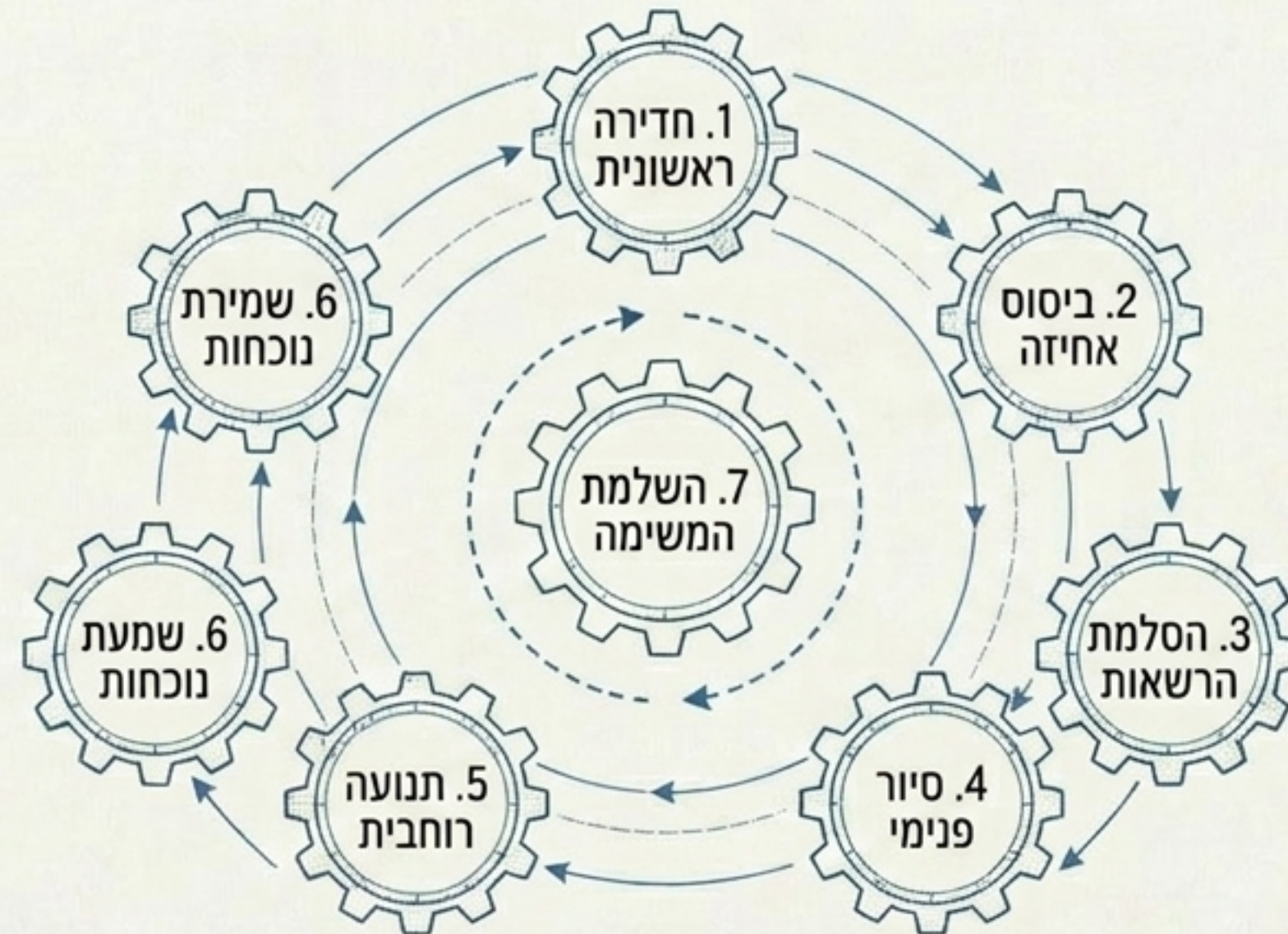


תחבורה

(Source: Intelligence Report, 2024)

מסע התוקף: שרשרת התקיפה (Kill Chain) של ה-APT

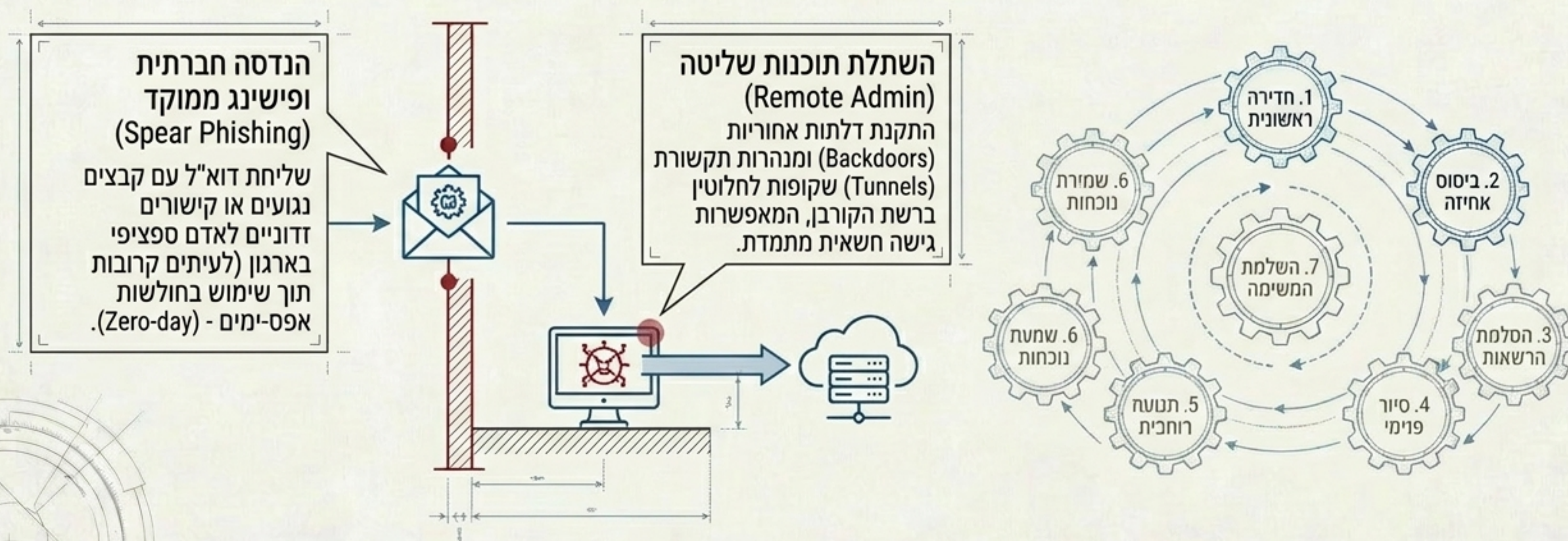
חברת Mandiant, במחקרה משנת 2013 על מתקפות סייבר בחסות ממשלתית, איפיינה מחזור חיים בן 7 שלבים. תהליך זה הינו רציף וחוזר על עצמו כל עוד המשימה נמשכת.



(Source: Intelligence Report, 2024)

שלב 1-2: חדירה ראשונית וביסוס אחיזה

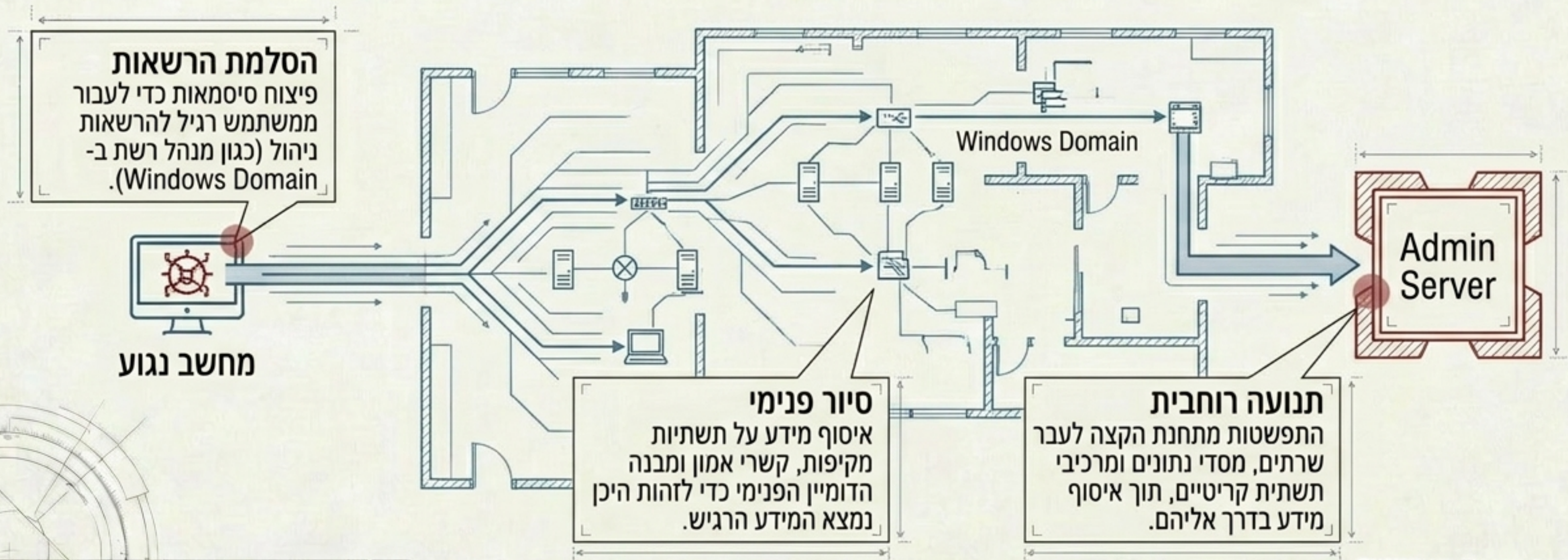
התקיפה מתחילה לרוב מנקודת התורפה הקלה ביותר – גורם אנושי או אתר חיצוני. לאחר החדירה, התוקפים פותחים ערוצים נסתרים החוצה אל עבר שרתי השליטה והבקרה שלהם.



(Source: Intelligence Report, 2024)

שלב 3-5: הסלמת הרשאות, סיור ותנועה רוחבית

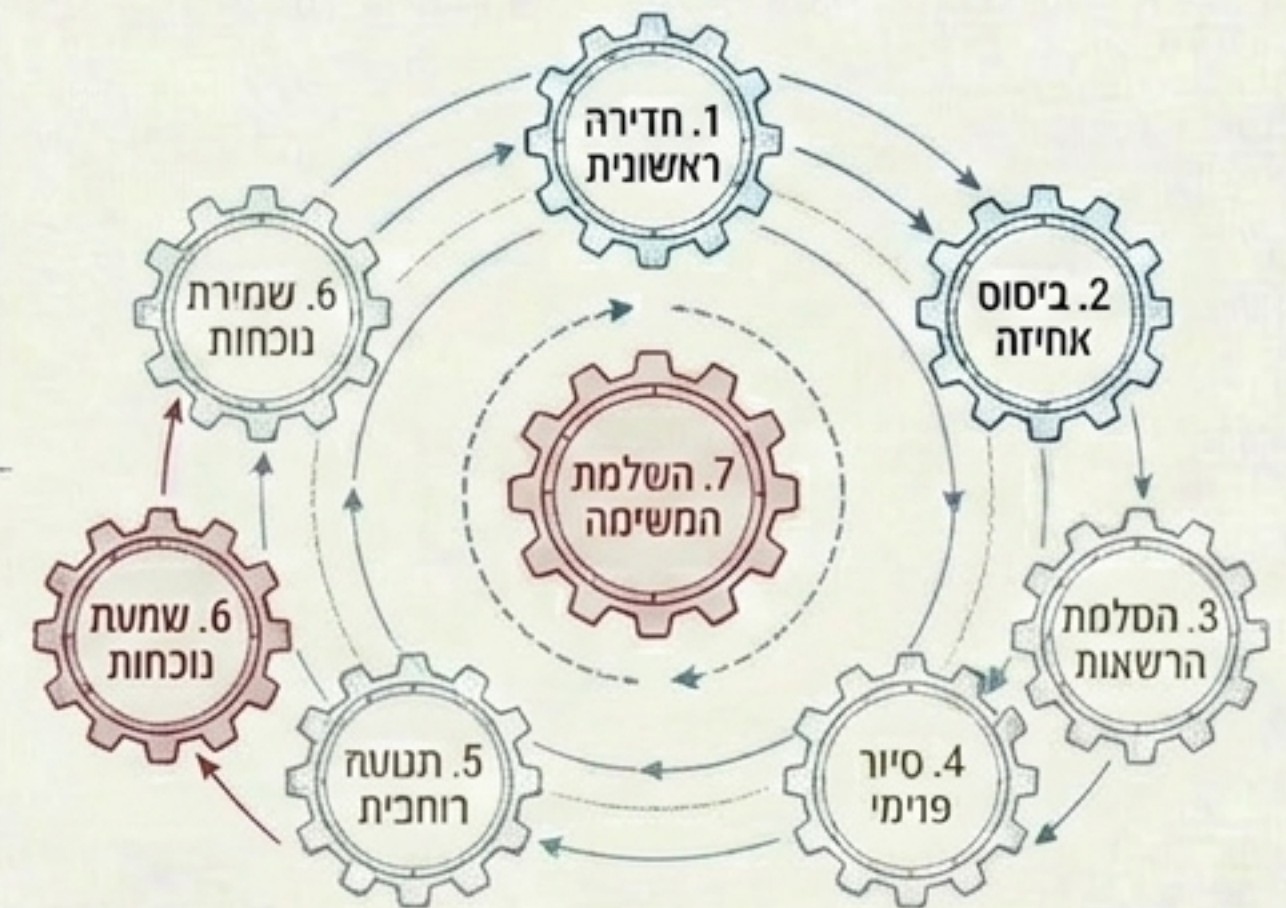
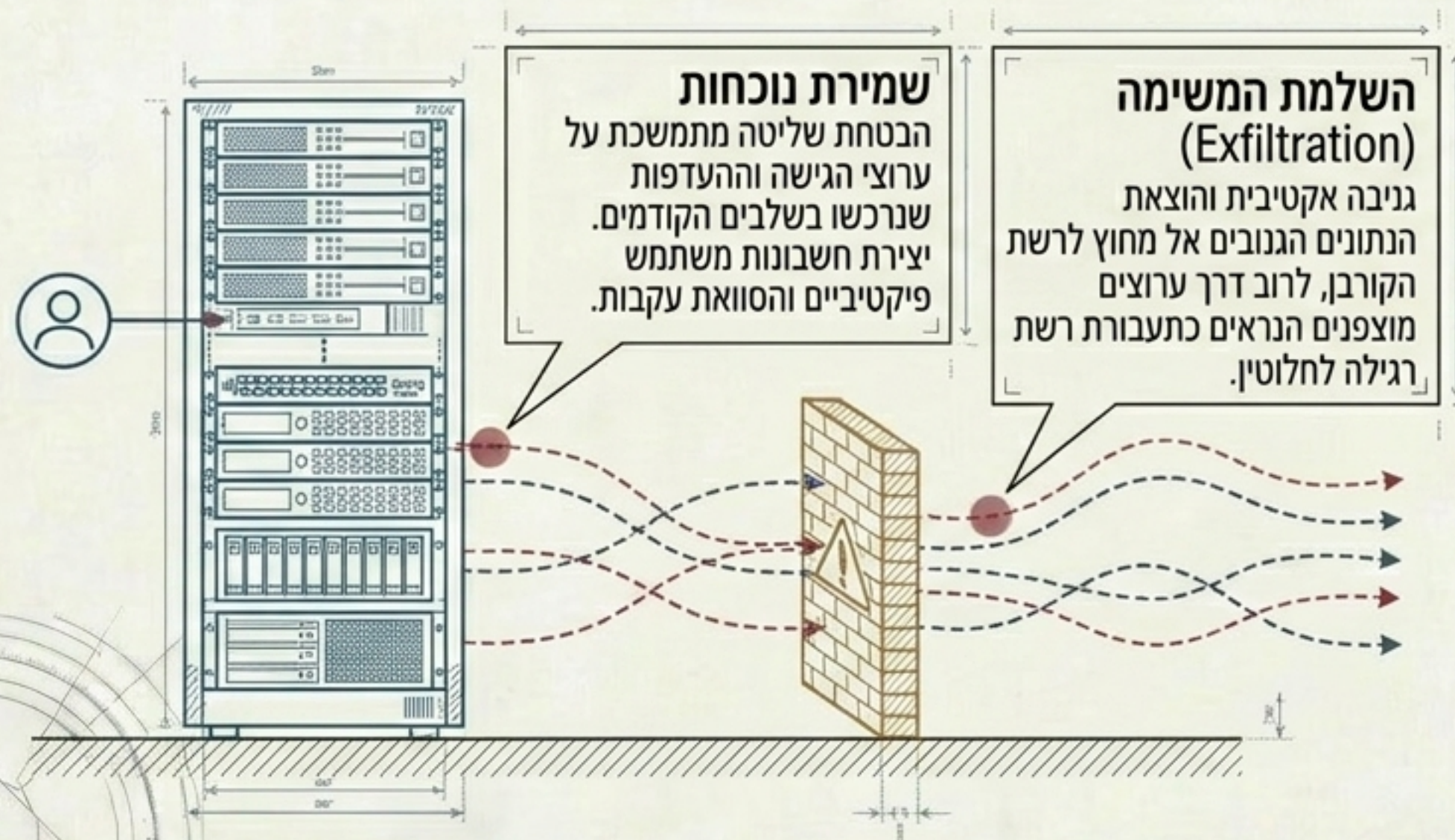
מחשב יחיד שנפרץ אינו המטרה – הוא רק קרש קפיצה. התוקפים מנצלים את דריסת הרגל הראשונית כדי למפות את הרשת הפנימית ולכבוש תחנות נוספות.



(Source: Intelligence Report, 2024)

שלב 6-7: שמירת נוכחות והשלמת המשימה

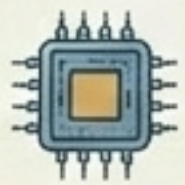
לאחר ביסוס השליטה, הארגון הופך למעשה לסניף מידע פתוח עבור התוקף. על פי ממצאי Mandiant, משך הזמן הממוצע בו שלטו תוקפים ברשת הקורבן עמד על שנה, ובמקרים החמורים ביותר – כמעט חמש שנים.



(Source: Intelligence Report, 2024)

שחקני מפתח: מטריצת איומים מדינתיים

שחקני APT משויכים לרוב למנגנוני מודיעין וצבא של מדינות ריבוניות. לכל קבוצה ישנו מוקד עניין, טקטיקה ורשימת שמות (אליאסים) המזהים אותה בקהילת הסייבר.

סין (China)	דוגמאות לקבוצות: PLA Unit 61398, Volt Typhoon, Double Dragon (APT41), Mustang Panda.	 
	מאפיינים: ריגול תעשייתי, גניבת קניין רוחני, התבססות ארוכת-טווח בתשתיות קריטיות מערביות.	
רוסיה (Russia)	דוגמאות לקבוצות: Cozy Bear (APT29), Fancy Bear (APT28), Sandworm.	 
	מאפיינים: שיבוש מערכות מסיבי (Wipers), לוחמה פסיכולוגית והתערבות פוליטית.	
איראן (Iran)	דוגמאות לקבוצות: Charming Kitten, MuddyWater.	 
	מאפיינים: מעקב אחר מתנגדי משטר, התקפות סייבר על תשתיות אזוריות וגלובליות.	
צפון קוריאה (North Korea)	דוגמאות לקבוצות: Lazarus Group, Kimsuky.	 
	מאפיינים: גניבת כספים מוסדית, מתקפות כופרה להכנסת מטבע חוץ לקופה הלאומית.	

(Source: Intelligence Report, 2024)

אבן הרוזטה של מודיעין הסייבר: פענוח שמות הקבוצות

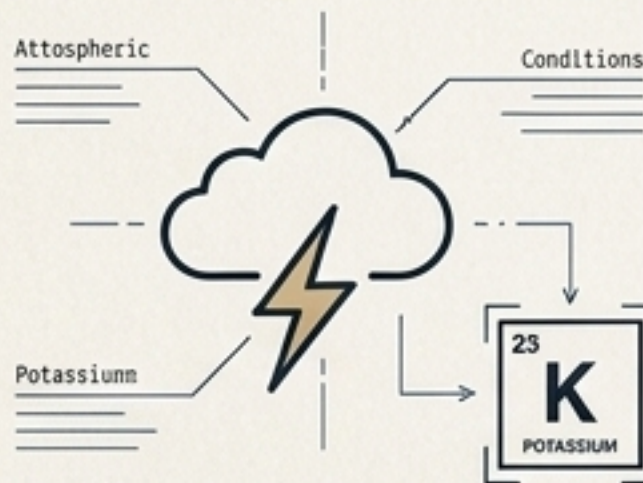
ארגונים נפרדים מנתחים נתונים שונים ויוצרים מערכות שיום (Naming Conventions) ייחודיות לאותן קבוצות. כך זה עובד בפועל:

Microsoft



• שיטת שיום: תופעות מזג אוויר (בעבר: יסודות מהטבלה המחזורית).

• דוגמה: Volt Typhoon (POTASSIUM): (לשעבר:).



CrowdStrike



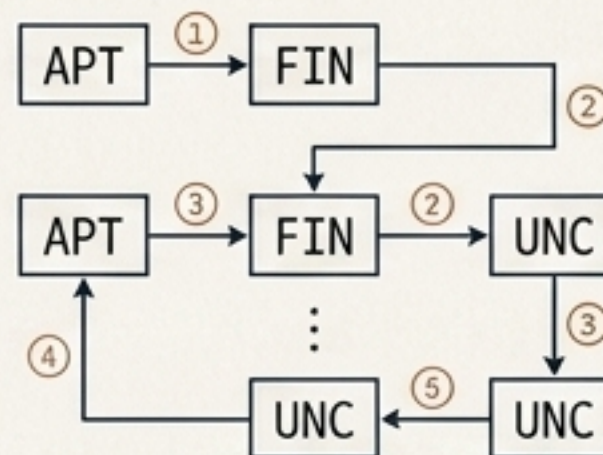
• שיטת שיום: בעלי חיים המשויכים למדינות שונות (כגון "Bear" לרוסיה, "Kitten" לאיראן, "Spider" לפשיעת סייבר).
• דוגמה: Cozy Bear.



Mandiant



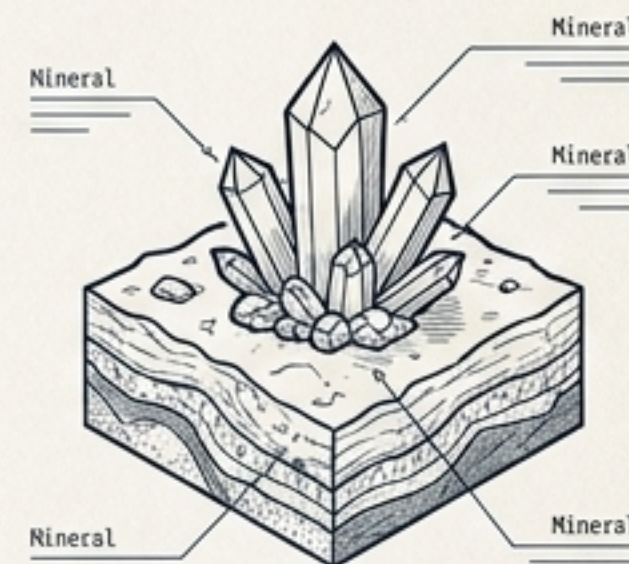
• שיטת שיום: קיצורים ממוספרים (APT למדינות, FIN לפשיעה, UNC לקבוצות שטרם סווגו).
• דוגמה: APT1, FIN7.



Dragos



• שיטת שיום: מינרלים מן הטבע.



בלימת האיום: הגנה מסורתית מול הגנה אקטיבית

עקב עשרות מיליוני וריאציות של נוזקות מתוחכמות, קשה להפריד את הרעש מתעבורה לגיטימית. טכנולוגיות מסורתיות פשוט אינן מספיקות כדי לאתר ולנטרל איומי APT.

הגנת סייבר אקטיבית (Active Cyber Defense)

1. **אמצעים:** מודיעין איומי סייבר (Threat Intelligence), ציד איומים אקטיבי (Threat Hunting).

2. **היתרון:** גישה פרואקטיבית המבוססת על מתודולוגיית "אתר, קבע, סים" (Find, Fix, Finish). זיהוי תעבורת השליטה והבקרה (C&C) של התוקפים ברמת הרשת, תוך שילוב אנליזה של התנהגות חריגה.

גישת הגנה מסורתית (Traditional)

1. **אמצעים:** ניתוחי יומנים עמוקים (Log Analysis), חומות אש סטנדרטיות (Firewalls).

2. **הבעיה:** קושי עצום בהפרדת תעבורת התקיפה ה"שקטה" מתוך רעש הרשת הלגיטימי. נכשלת בזיהוי איומים שאינם מוכרים מראש.

נקודת התורפה האולטימטיבית: הגורם האנושי

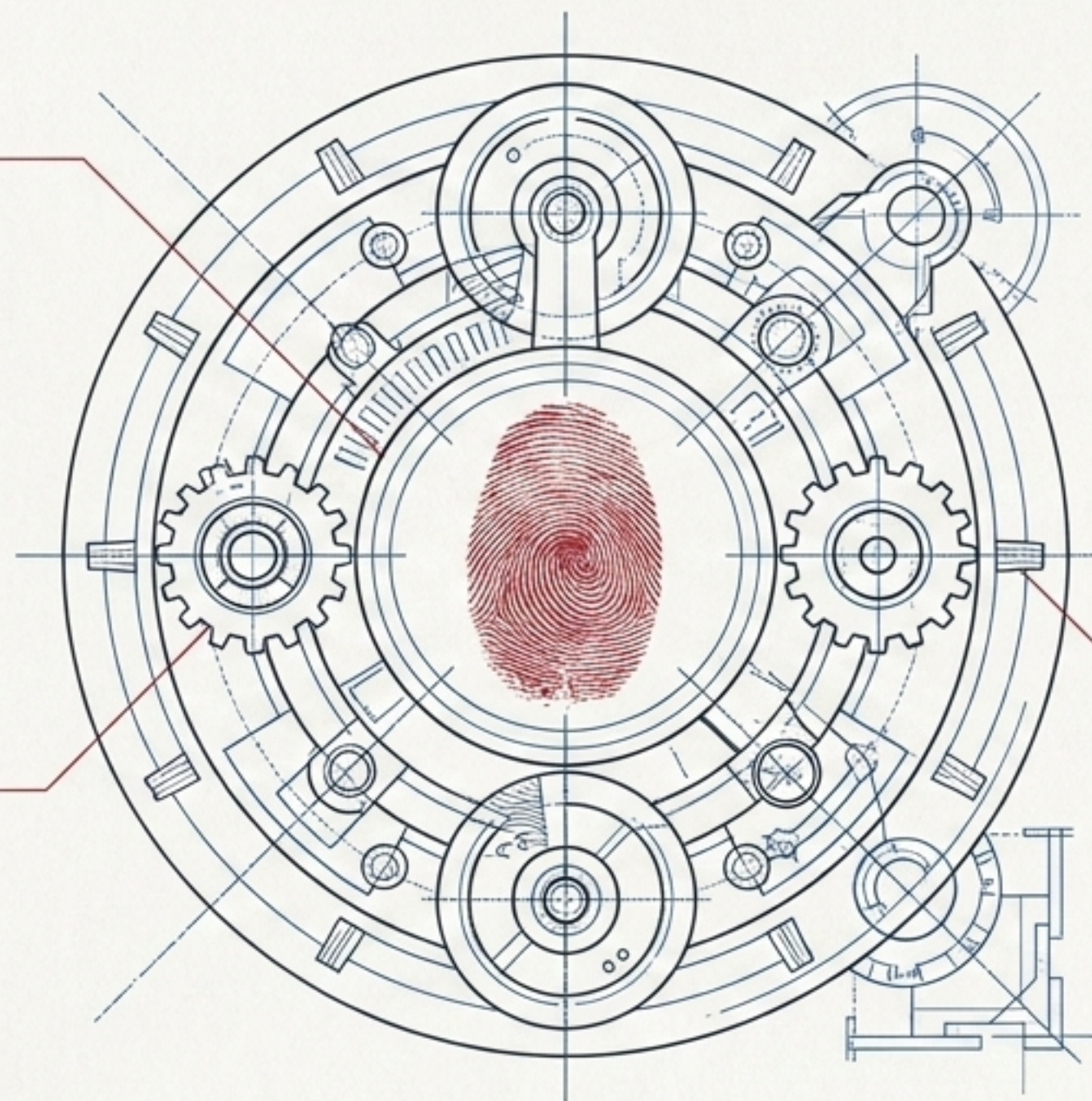
למרות השימוש בכלים הטכנולוגיים המתקדמים ביותר שקיימים ברמת מדינה, נקודת התורפה המשמעותית ביותר נותרה המשתמש האנושי.

אשליה של חוסן טכנולוגי

חברות משקיעות הון בהגנה אקטיבית, אך חולשות סייבר המיוחדות על ידי בני אדם (HICV) עדיין אינן מובנות או מנוהלות כראוי, ומהוות וקטור תקיפה מרכזי.

ראשית ההיסטוריה, הווה העתיד

אזהרות מפני אימיילים של הנדסה חברתית החלו כבר בשנת 2005. גם כיום, חדירה ראשונית מתבצעת לרוב באמצעות מניפולציה אנושית (Spear Phishing).



המסקנה האסטרטגית

כלי הגנה לא יעצרו איום מתקדם ללא תרבות ארגונית מודעת, הכשרה מתמדת, וסביבה שלא מאפשרת לטעות אנוש אחת להפוך להשתלטות עוינת בת 5 שנים.

(Source: Intelligence Report, 2024)